

Security Audit Report

Controls & Compliance Assessment

Prepared by

Monica Navarro

June 2026

PROJECT SUMMARY

This assessment evaluated Botium Toys' administrative, technical, and physical security controls, as well as compliance with PCI DSS, GDPR, and SOC best practices.

Objectives

- Evaluate existing security controls
- Identify security gaps
- Assess regulatory compliance
- Recommend improvements to reduce organizational risk

Security Controls Assessment

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties

- | | | |
|-------------------------------------|-------------------------------------|---|
| ☒ | ☐ | Firewall |
| ☐ | ☒ | Intrusion detection system (IDS) |
| ☐ | ☒ | Backups |
| ☒ | ☐ | Antivirus software |
| ☐ | ☒ | Manual monitoring, maintenance, and intervention for legacy systems |
| ☐ | ☒ | Encryption |
| ☐ | ☒ | Password management system |
| ☒ | ☐ | Locks (offices, storefront, warehouse) |
| ☒ | ☐ | Closed-circuit television (CCTV) surveillance |
| ☒ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) |
-

Compliance Assessment

Payment Card Industry Data Security Standard (PCI DSS)

- | Yes | No | Best practice |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Only authorized users have access to customers' credit card information. |
| ☐ | ☒ | Credit card information is stored, accepted, processed, and transmitted internally in a secure environment. |
| ☐ | ☒ | Implement data encryption procedures to better secure credit card transaction touchpoints and data. |
| ☐ | ☒ | Adopt secure password management policies. |

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

Executive Summary & Recommendations

After conducting a security controls and compliance assessment for Botium Toys, I found that the organization has implemented several important safeguards, including firewall protection, antivirus software, physical security controls, CCTV surveillance, and fire prevention systems. While the assessment identified opportunities for improvement in access controls, disaster recovery planning, encryption, password management, and regulatory compliance, the organization demonstrated a commitment to addressing these gaps and strengthening its overall security posture. I

recommend that Botium Toys continue implementing the proposed security enhancements to reduce risk, improve compliance, and better protect its systems, assets, and customer data.